

11. Seguridad

gabysql 0.2.0 | commit ed4135c | 10 de septiembre de 2026 | Fuente: 11-security.md

La política y auditorías completas están en SECURITY, SECURITY_LAYERS y los informes fechados. Este documento separa controles observados de garantías no comprobadas.

Controles implementados

- Lock exclusivo de archivo, CRC32 de páginas/WAL, límites de body/conexiones y profundidad/iteración.
- Token HTTP opcional; usuarios/roles, GRANT/REVOKE y RLS dentro del motor.
- Hashing de contraseñas con esquemas persistidos; el default documentado en código/roadmap debe verificarse antes de auditoría criptográfica.
- CSRF token, cookies HttpOnly/SameSite, comparación constante y restricción de destinos en phpgabyadmin.
- Validación de nombres de DB/rutas e identificadores; errores numerados sin necesidad de parsear texto.
- Workflows de auditoría, dependencias, secretos, imágenes y seguridad de Actions.

Superficie y límites

El server habla HTTP plano: TLS y exposición pública requieren proxy/firewall. El token compartido no equivale a un IAM completo del transporte. El modelo single-writer limita carreras de archivo, no reemplaza controles del sistema operativo. El SQL y los logs pueden contener secretos o PII. El modelador carga Google Fonts desde un tercero.

Riesgos por clase

Riesgo	Control/estado
Inyección SQL en clientes	Use parámetros/constructores seguros cuando existan; el admin debe tratar input como SQL deliberado
Path traversal de DB	Normalización y modo -dir; conservar pruebas
CSRF/admin	Token por sesión y SameSite; exponer solo local/proxy
CORS	No identificado como contrato general; requiere validación de despliegue
Cifrado en reposo	No documentado; delegar a disco/OS
TLS	Ausente en server integrado
Retención de logs	No documentada organizacionalmente
Dependencias vulnerables	Core sin crates externos, pero toolchains, PHP, imágenes y Actions requieren escaneo continuo

No se realizaron ataques ni pruebas destructivas. Los controles deben revalidarse al desplegar, porque red, secretos, permisos y proxy están fuera del repositorio.